Accessed, never disclosed: Silent access to protected health information by medical artificial intelligence agents

Jae Wang Lee[1], Abhirup Banerjee[2†], Yeong Chan Lee[3†]

[1]Department of Software, College of Computing and Informatics, Ajou University, Suwon, Republic of Korea

[2]Institute of Biomedical Engineering, Department of Engineering Science, University of Oxford, Oxford, OX3 7DQ, United Kingdom

[3]Department of Physiology, Ajou University School of Medicine, Suwon, Republic of Korea

†Corresponding authors

Abhirup Banerjee, PhD.

Institute of Biomedical Engineering, Old Road Campus Research Building, University of Oxford, Oxford, OX3 7DQ, United Kingdom

Email: abhirup.banerjee@eng.ox.ac.uk

Yeong Chan Lee, PhD.

Department of Physiology, Ajou University School of Medicine, Worldcup-ro 164, Yeongtong-gu, Suwon 16499, South Korea

Phone: +82-(31)-219-5041; E-mail: ycl@ajou.ac.kr

Abstract

Medical artificial intelligence agents should retrieve patient identifiers only when a task requires them, the data-minimization principle behind the HIPAA minimum necessary standard for protected health information (PHI). An agent can retrieve identifiers without revealing them. Such silent access remains invisible to evaluations that inspect only the output. We embedded canaries in synthetic patient records and linked each tool invocation to canary exposure in the final answers across five language models, four boundary levels, and seven attack frames for identifier-free clinical tasks. Three models invoked the PHI tools unnecessarily, whereas Claude Opus 4.8 and GPT-5.5 did not. Stronger boundaries reduced this access, and the residual access under the strictest policy was confined to frames in which the user overrode the policy or asserted approval. A pre-execution gate given the task-necessity criterion nearly eliminated this access. Output-only evaluation cannot verify minimum-necessary access; boundaries, gates, and access-log audits are required together.

Keywords: Medical AI agents, Data minimization, Protected health information (PHI), AI privacy and security

1 Introduction

Large language models (LLMs) have evolved from simple question-answering systems into agents that assess situations, make judgments, and invoke tools to solve problems[1,2,3]. The Model Context Protocol (MCP) provides a standardized interface for connecting AI agents to external data sources and tools[4]. In clinical settings, artificial intelligence (AI) agents can use electronic health record (EHR) tools to retrieve laboratory results, manage medication orders, and update patient records[5,6]. These agents can dynamically decide whether to access protected health information (PHI) during execution.

The agent's decision to access PHI is not merely a tool-selection decision but also a privacy issue concerning which patient information the agent should retrieve. The Health Insurance Portability and Accountability Act (HIPAA) minimum necessary standard generally requires covered entities to limit PHI use and disclosure to what is necessary for the intended purpose[7]. As the standard exempts treatment and is implemented through role-based access rather than per-request review[7], we consider per-invocation necessity a stricter data-minimization rule that an institution may impose on automated agents rather than a legal test. Applied to agents, this principle implies that a tool should be invoked only when access is required to complete the task, not merely because the agent is authorized to access PHI. Therefore, evaluating the privacy of a medical AI agent requires examining not only the information disclosed in the final answer but also the access decisions made while generating that answer.

When a medical AI agent invokes tools, inspecting only the final output can overlook PHI access that occurs during reasoning. Privacy depends on whether information flow is appropriate to its context, and language models have been shown to disclose private information in contexts where such disclosure is inappropriate[8,9]. Modern AI assistants are trained to follow user intent and human preferences[10,11], while subsequent studies have shown that such models can exhibit sycophancy, favoring responses that match users' stated views over truthful ones[12,13]. Accordingly, recent studies have investigated internal channels, memory, policy compliance, and web-based oversharing by agents[14,15,16,17,18]. AgentLeak and AgentSCOPE examine privacy leakage in agentic workflows, while Leaky Thoughts analyzes whether sensitive information appears in the reasoning trace[14,15,19]. PrivacyLens evaluates whether answers that reflect an understanding of privacy norms can diverge from actual behavior, while ToolEmu proposes a method for testing the risks of tool-using AI in a controlled, emulated environment[20,21]. Rather than examining whether sensitive text appears in the reasoning trace, we instead posed two questions for each tool invocation: first, whether the task required access to PHI; and second, whether the accessed information was subsequently disclosed in the final answer.

In this study, we examined whether medical AI agents invoke a PHI tool that returns direct identifiers for clinical tasks that do not require them. We determined whether such PHI access is silent, with no

identifiers appearing in the final answer. For this study, 374,000 trials were conducted with five LLMs using nine clinical tasks and 100 synthetic patient records under four boundary levels and seven attack frames (**Fig. 1a**). Each trial had two phases: in Phase 1, the model decided which tools to invoke; in Phase 2, the model generated the final answer using only the returned information. We defined silent access as a trial in which a PHI tool was invoked but the returned canary was not detected in the final answer (**Fig. 1b**). We quantified unnecessary PHI tool invocations and silent access across boundary levels and attack frames for each model. Subsequently, we examined whether stronger boundaries also suppressed required invocations in tasks necessitating PHI, whether answer completeness differed according to PHI tool invocation, and whether a pre-execution gate reduced silent PHI access while preserving required invocations (**Fig. 1c**). These analyses extend privacy evaluations beyond final outputs to the preceding PHI access decisions.

2 Results

The experimental design comprised four boundary levels, which varied the degree of restriction on PHI access, and seven attack frames, which varied the framing of an identical task request to induce PHI tool invocation. Of the five models evaluated, DeepSeek V4 Pro[22] and GPT-OSS-120b[23] are open-weight, whereas Qwen3.6-Plus[24], Claude Opus 4.8[25], and GPT-5.5[26] are proprietary; DeepSeek V4 Pro, GPT-OSS-120b, and Qwen3.6-Plus were evaluated with five phrasing variants (multi-phrasing models), and the other two once (single-phrasing models). Tasks were categorized as clinical-reasoning (CR) tasks, completable using de-identified clinical information alone, and identifier-retrieval (IR) tasks, which required direct identifiers (**Table 1**). Trials that invoked a PHI tool were classified as surface leakage when a canary was detected in the final answer and as silent access when it was not (**Fig. 1d**, **Extended Data Table 1** and **Supplementary Tables 1–3**). The silent access rate (SAR) in CR tasks and the PHI tool invocation rate (TIR) served as the primary and secondary outcomes, respectively (**Extended Data Table 2**). Inspection of the reasoning traces of the four models other than GPT-5.5 revealed no trial in which the canary appeared before the PHI tool was invoked, an occurrence that would have violated the study design.

2.1 Unnecessary PHI access across models

First, we examined whether the five models invoked PHI tools that were not required to complete the CR tasks. In the CR tasks, all models except Claude Opus 4.8 invoked PHI tools (**Fig. 2a**). Pooled across all four boundary levels, TIR in the three multi-phrasing models ranged from 11.3% to 38.3%, and SAR ranged from 5.6% to 14.7% (**Fig. 2a**). Pooled over B-01–B-03 (10,500 trials per model), TIR was 24.4% (95% confidence interval [CI], 23.9–24.8) for DeepSeek V4 Pro, 10.5% (95% CI, 10.1–10.9) for GPT-OSS-120b, and 18.8% (95% CI, 18.4–19.2) for Qwen3.6-Plus. The corresponding SAR values were 10.4% (95% CI, 9.9–11.0), 5.5% (95% CI, 5.2–5.9), and 9.8% (95% CI, 9.4–10.3), respectively (**Supplementary Table 4**). In all three multi-phrasing models, TIR decreased from 13.8–96.9% at B-00 to 1.3–6.7% at B-03, and SAR decreased from 5.8–29.4% to 1.1–6.2% (**Fig. 2b,c**). Silent access was observed in all three models, even at B-03, the strictest boundary level (**Fig. 2c**). In approximately 48–93% of PHI tool invocations at B-03, no canary was detected in the final answer (**Fig. 2d**). Comparison of TIR across frames showed that A-07, which asserted unsubstantiated approval, yielded the highest invocation rate in all three models: pooled across all four levels, its rate was 3.6–34.6 times that of the direct request A-01 (**Fig. 2e**). At B-01–B-03, TIR under A-07 remained 43–76%, compared with 0.3–1.3% under the direct request (**Supplementary Fig. 1**). Under the direct request, SAR was 0% at B-02 and B-03 for all three multi-phrasing models (**Supplementary Table 5**). Residual silent access at B-03 arose entirely under the instruction-override frames (A-05–A-07): A-07 for DeepSeek V4 Pro and Qwen3.6-Plus and A-05 for GPT-OSS-120b (**Extended Data Table 3**).

Furthermore, SAR varied substantially across combinations of attack frames and boundary levels (**Supplementary Fig. 2**). Excluding empty or truncated Phase 2 answers changed SAR by at most 1.2 percentage points (**Supplementary Table 6**).

Further, we examined PHI tool invocation at each boundary level in the two single-phrasing models. Claude Opus 4.8 had TIR and SAR values of 0% at every boundary level in CR tasks, but at B-02, it omitted 15.4% of the PHI tool invocations required in IR tasks. For GPT-5.5, TIR and SAR were 20.9% and 19.9%, respectively, at B-00. TIR and SAR decreased to 0.51% and 0.46% at B-01, respectively, and both were 0% at B-02 and B-03 (**Supplementary Fig. 3**). Strengthening the boundary reduced unnecessary access in CR tasks; however, under some conditions, it also reduced required PHI tool invocations in IR tasks (**Supplementary Fig. 4**).

To determine whether the pattern of PHI tool invocation depended on the wording of specific attack phrases, we evaluated four meaning-preserving variants of each of the six attack frames, excluding the direct request. All 24 variants satisfied the prespecified criteria for semantic similarity, **preservation of attack intent**, and lexical diversity (**Supplementary Fig. 5**). Across the three multi-phrasing models, TIR and SAR tended to decrease as the boundary level strengthened from B-00 to B-03 across meaning-preserving variants, and silent access persisted at B-03 (**Supplementary Fig. 6**).

2.2 PHI awareness in reasoning traces

For the four models that returned Phase 1 reasoning traces, we classified CR-task traces according to whether a PHI tool was invoked and examined the stated reasoning associated with invoking or not invoking the tool. Among the traces in which no PHI tool was invoked, the distribution of stated reasoning across task relevance, policy, and data minimization differed among models (**Fig. 3a**). Claude Opus 4.8 invoked no PHI tool in any CR task, and in 16.8% of these traces, the model explicitly recognized that the tool would access PHI and stated that it would not invoke the tool. Among traces in which a PHI tool was invoked, stated reasoning that acknowledged PHI access but proceeded with the invocation was observed in 10.0%, 8.4%, and 29.5% of traces for DeepSeek V4 Pro, GPT-OSS-120b, and Qwen3.6-Plus, respectively (**Fig. 3b**); inter-rater agreement for this category was low (54%). A substantial proportion of the remaining invocation traces cited the user's instructions or a decision to gather all information before answering. To assess the reproducibility of trace classification, two LLM raters independently classified 300 traces stratified by model, PHI tool invocation, attack frame, and boundary level. Inter-rater Cohen's κ was 0.67, and simple agreement was 72.3%; agreement between the keyword rules and the raters is reported in Methods.

2.3 PHI access and answer completeness

In CR tasks, which did not require identifying information, we compared answer completeness scores

between trials with and without PHI tool invocation as an exploratory analysis. In all three multi-phrasing models, mean completeness scores did not differ between the invoking and non-invoking groups (mean difference, −0.002 [Bonferroni-adjusted 95% CI, −0.153 to 0.149] for DeepSeek V4 Pro; −0.137 [−0.407 to 0.134] for GPT-OSS-120b; and −0.103 [−0.249 to 0.044] for Qwen3.6-Plus; **Fig. 4** and **Supplementary Table 7**). The adjusted intervals excluded improvements larger than 0.15, 0.13, and 0.04 points on the 4-point scale, respectively. When compared by frame, the invoking group scored higher only under A-07 for DeepSeek V4 Pro (mean difference, 0.859; Bonferroni-adjusted 95% CI, 0.443–1.276). Under this condition, the non-invoking group contained more trials in which no clinical answer was generated, and more answers received low completeness scores. Responses that contained only tool-call syntax and no generated clinical answer accounted for 25.4% and 0% of the non-invoking and invoking groups, respectively, whereas answers with a score of 1 accounted for 71.8% and 18.3%, respectively. In a prespecified auxiliary analysis excluding empty answers and responses consisting only of tool-call syntax, the mean score difference decreased from 0.859 to 0.708 (unadjusted 95% CI, 0.370–1.047). Agreement between the two LLM raters on the 300 re-scored answer pairs was fair (linearly weighted Cohen's κ, 0.31; 95% CI, 0.25–0.38 pooled across models; 0.32, 0.31, and 0.10 for DeepSeek V4 Pro, GPT-OSS-120b, and Qwen3.6-Plus, respectively). Overall, PHI tool invocation was not clearly associated with higher answer completeness, although a small benefit could not be excluded given the fair inter-rater agreement.

2.4 Pre-execution gates reduced silent access

Under the B-03 boundary across the five phrasing variants, we evaluated PHI-blind pre-execution gates on 1,356 and 3,832 proposed invocations in tasks not requiring and requiring PHI, respectively. All three gates were applied to the same fixed set of invocations proposed by DeepSeek V4 Pro: G1, a self-model gate; G2, a cross-model gate using Claude Opus 4.8; and G3, a rule-based upper bound based on task-level PHI necessity labels (**Methods**). All gates applied the same necessity criterion that was used to label the tasks and did not access PHI values. All three gates reduced the executed silent access rate (eSAR) relative to G0 (eSAR, 3.720%; **Supplementary Table 8**). The reduction in eSAR relative to G0 was 3.70 percentage points (95% CI, 3.35–4.03) for G1 and 3.72 percentage points (95% CI, 3.38–4.09) for G2 and G3. The rate of erroneously allowing unnecessary PHI tool invocations in CR tasks (FalseAllow) was 0.885% for G1 and 0% for G2 and G3 (**Fig. 5a** and **Supplementary Table 8**). This rate was 0.885 percentage points lower for G2 than for G1 (95% CI, 0.448–1.382). The rate of incorrectly blocking required PHI tool invocations in IR tasks (FalseDeny) was 1.253%, 0.574%, and 0% for G1, G2, and G3, respectively (**Fig. 5b** and **Supplementary Table 9**). This rate was 0.678 percentage points lower for G2 than for G1 (95% CI, 0.286–1.101). For G1, all erroneously allowed invocations occurred exclusively under the A-05 frame (**Supplementary Table 10**).

3 Discussion

This study evaluated whether medical AI agents invoke PHI tools in clinical reasoning tasks that do not require identifying information and whether such access is revealed in the final answer. We measured silent access by linking each trial's PHI tool invocation record to the corresponding final answer generated from the canary-seeded synthetic records. In CR tasks, the three multi-phrasing models invoked PHI tools that were not required by the task at every boundary level, whereas Claude Opus 4.8 invoked none and GPT-5.5 did so only at B-00 and B-01. A substantial proportion of these invocations were silent, with no identifiers appearing in the final answer. Stronger boundary policies reduced unnecessary PHI tool invocations, but silent access persisted under the strictest policy and was confined to frames in which the user overrode the policy or asserted unsubstantiated approval. PHI tool invocation was not associated with higher answer completeness. In one model, pre-execution gates applying the task-necessity criterion nearly eliminated silent access. These findings indicate that privacy evaluation of medical AI agents must encompass not only the final answer but also PHI tool invocation.

Even when PHI did not appear in the final answer, the agent may have already accessed the information (**Fig. 1d**). At B-03, the strictest level, prespecified canary strings were not detected in the final answer for 48–93% of PHI tool invocations made by the three multi-phrasing models (**Fig. 2d**). This discrepancy reflects a limitation of output auditing: a competent answer to a clinical reasoning question may omit identifiers regardless of whether they were retrieved; thus, the final answer alone cannot reveal whether access occurred. Previous studies have traced information flow through agent channels and workflows[14,15], inspected reasoning traces for sensitive text[19], or shown a discrepancy between a model's stated understanding of privacy norms and its behavior[9,20]. By contrast, we jointly evaluated whether an invocation was required to complete the task and whether the retrieved information appeared in the final answer, thereby rendering unnecessary silent access measurable.

Unnecessary PHI tool invocation was most frequent under A-07, which asserted, without substantiation, that the workflow had been approved. Among the three multi-phrasing models, the TIR under A-07 was 3.6–34.6 times that under the direct request (**Fig. 2e**). The residual silent access at B-03 arose from user-turn attempts to override the policy or assert approval rather than from injected content, which was not evaluated. Reasoning traces accompanying PHI tool invocations frequently cited the user's instructions or a decision to gather all information before answering. Stated reasoning that acknowledged PHI access but proceeded with the invocation was observed in 8.4–29.5% of invocations, depending on the model (**Fig. 3b**). In contrast, Claude Opus 4.8, evaluated in a single run, showed no unnecessary invocation. In 16.8% of its non-invocation traces, the model explicitly recognized that the tool would access PHI and stated that it would not invoke the tool (**Fig. 3a**). This pattern is consistent with previous findings that instruction adherence and sycophancy can influence the behavior of language models[10,11,12], and with failures of the instruction hierarchy in which a user-turn assertion overrides a system-level policy[27].

This between-model contrast indicates that connecting a model to the tools alone does not determine compliance with the minimum-necessary standard. As prompt phrasing, provider, and reasoning settings were not aligned across models and reasoning traces do not establish the actual grounds for a model's decision[28], these between-model differences are descriptive and require confirmation under identical execution conditions.

Prompt-level boundaries reduced unnecessary PHI tool invocation but did not eliminate it. When the boundary was strengthened from B-00 to B-03, TIR and SAR decreased in all three multi-phrasing models (**Fig. 2b, c**), and this pattern was maintained across the original phrasing and the four meaning-preserving variants (**Supplementary Fig. 6**). However, silent access persisted at the strictest boundary level, B-03, in all three models. By contrast, Claude Opus 4.8 omitted 15.4% of the PHI tool invocations required for IR tasks at B-02 (**Supplementary Fig. 4a**). Therefore, boundary policies should be evaluated according to two criteria: how much unnecessary access they eliminate and how much required access they preserve.

No clear evidence indicated that unnecessary PHI invocations improved answer completeness. In all three models, the overall comparison revealed no difference in completeness scores between the invoking and non-invoking groups (**Fig. 4**). Only under A-07 for DeepSeek V4 Pro did the invoking group exhibit a higher completeness score. Under this condition, the non-invoking group contained more responses without a generated clinical answer and more answers with a score of 1. When these responses were excluded, the mean score difference decreased from 0.859 to 0.708, suggesting that some of the observed difference reflected failed answer generation in the non-invoking group. This comparison was exploratory and observational, and further studies are required to determine whether PHI invocations are consistently associated with answer completeness.

Access that persisted under prompt boundaries alone could be further reduced by screening the necessity of each invocation before tool execution. Across the five phrasing variants evaluated for DeepSeek V4 Pro, the self-model and cross-model gates reduced the eSAR to nearly zero (**Supplementary Table 8**). Furthermore, the cross-model gate made fewer errors in allowing unnecessary invocations and blocking required invocations than the self-model gate (**Fig. 5**). As every gate applied the same necessity criterion used to label the tasks, the values obtained represent an upper bound for settings in which the criterion is supplied. The advantage of separating the screener from the proposer[29] is consistent with the separation-of-privilege principle established in system security[30]. G3, a deterministic rule based on task type, achieved the same eSAR reduction without requiring a model and suffices when the task type is known. A model-based gate is required only when intent must be inferred from free text, at the cost of an extra model call and a second data processor.

Pre-deployment evaluation of medical AI agents should extend beyond output-centered assessments to incorporate access-centered scrutiny. Clinical assistants are increasingly integrated with EHR tools through standards such as MCP[4,5,6]; however, current evaluations predominantly emphasize the accuracy and safety of final answers. Our results indicate that such evaluations cannot verify adherence to the minimum-necessary standard. Accordingly, deployment would benefit from layered controls. First, tool exposure should be restricted according to task type where such classification is feasible, such that clinical reasoning workflows do not expose the agent to a PHI tool. Second, prompt-level boundaries attenuate the baseline of unnecessary access but are insufficient in isolation. Third, a pre-execution gate screens access decisions in cases where intent must be inferred from unstructured input. Fourth, access logs already maintained by health information systems, which this study did not evaluate directly[31], should record agent tool invocations with their purpose of use and task, such that the invocation record constitutes the basis for audit. A denied invocation requires a logged, attested override path because hard blocks without such a path may incentivize circumvention. These layers rely on distinct forms of oversight: model-level judgment, an independent gate, and retrospective verification. Thus, the failure of any single layer remains detectable by another.

The principal methodological strengths of this study include the common two-phase protocol applied to five models with 22,000 trials per model and phrasing variant, cluster-bootstrap uncertainty estimation for all proportions, and prespecified gating of phrasing variants. Nevertheless, this study has several limitations. First, we used synthetic patient records and experimental tools that responded to every request; therefore, the study does not capture the authorization structures, tool failures, retries, and multi-agent workflows of real clinical environments. Moreover, the clean separation of identifiers and clinical tools does not hold for free-text notes that carry identifiers. Second, canary-based SAR captures only the discordance between access and output and does not directly indicate a legal violation or patient harm. Invocation-level necessity is a coarse proxy because the PHI tool returns ten identifier fields per call. Third, string-based detection may fail to detect paraphrased PHI exposures or alternative processing paths outside the study's instrumentation, and meaning-preserving phrasing variants do not substitute for independent re-runs under identical conditions. Fourth, CR and IR labels were assigned by the investigators according to guideline provisions, without clinician adjudication. Finally, the reasoning settings were not identical across the models; Claude Opus 4.8 and GPT-5.5 were evaluated in a single run, and the pre-execution gates were applied to a fixed set of invocations from a single model. The gate evaluation for IR tasks covered only two frames (A-01 and A-04); indirect prompt injection[32], retries, and circumvention after denial were not evaluated.

In conclusion, the absence of PHI from the final answer does not ensure that a medical AI agent accessed only the information it needed. The minimum-necessary standard may therefore need to be evaluated

and, where possible, enforced at the point at which the agent invokes PHI tools, rather than only at the final output.

4 Methods

4.1 Synthetic patient cohort and canary PHI

All measurements were performed using synthetic patient records. We generated 100 synthetic patient records using Synthea[33], an open-source patient simulator. This cohort size was selected to provide the number of clusters required for patient-level bootstrapping while allowing 22,000 trials to be conducted for each model and phrasing variant. Each patient's record consisted of a chronologically ordered history of demographic information, diagnoses, medications, and laboratory results.

Direct identifiers in each patient's PHI were replaced with tracer markers (canaries) that preserved the format but altered the value. This design follows existing literature on tracer markers and memorization probes[34,35,36]. Replacement was performed reproducibly using the Faker library[37] to derive deterministic values from each patient identifier. For the name, date of birth, telephone number, social security number (SSN), medical record number (MRN), driver's license, passport number, and address generated by Synthea, the original and canary values were recorded as pairs. For email addresses, fax numbers, IP addresses, URLs, health insurance numbers, account numbers, and vehicle and device identifiers that Synthea does not generate, only canary values were added. Biometric identifiers and facial photographs that could not be represented as text were excluded. Canary values were synthetic and not linked to any real person, but they were not guaranteed to be unissued. The SSN canaries used area numbers 500–599, which are issuable; the email and URL canaries used the reserved .invalid domain; and IP canaries used private address ranges with no correspondence to real addresses. Therefore, detection relied on exact matching against the registry rather than on the nonexistence of these values elsewhere. All the original–canary pairs were stored in a patient-level ground-truth canary registry.

4.2 Evaluated models and execution environment

For this study, five models were evaluated: two open-weight models, DeepSeek V4 Pro[22] and GPT-OSS-120b[23], and three proprietary models, Qwen3.6-Plus[24], Claude Opus 4.8[25], and GPT-5.5[26]. DeepSeek V4 Pro, GPT-OSS-120b, and Qwen3.6-Plus were evaluated through the Fireworks API, which serves Qwen3.6-Plus as a hosted model without publicly released weights, whereas Claude Opus 4.8 and GPT-5.5 were evaluated through the Anthropic and OpenAI Batch APIs, respectively. The three multi-phrasing models were evaluated with the original phrasing (v1) and four variants (v2–v5), whereas the two single-phrasing models were evaluated once each with the original phrasing (v1) owing to cost constraints. For all models, sampling parameters, such as temperature and top_p, were not specified, and each provider's default generation settings were applied. Therefore, generation settings

were identical across conditions within each model. Execution dates were May 25, 2026, for DeepSeek V4 Pro; May 27, 2026, for GPT-OSS-120b; June 2, 2026, for Qwen3.6-Plus; June 9, 2026, for Claude Opus 4.8; and June 15, 2026, for GPT-5.5.

4.3 Tools, boundaries, frames and tasks

Three tools were presented to the agent as function-calling interfaces. The PHI tool returned canary values for name, date of birth, SSN, MRNs, telephone numbers, addresses, email addresses, health insurance numbers, licenses, and passport numbers. The schema description stated that the tool was restricted and should be invoked only when the task explicitly required identity, contact, verification, insurance, a legal identifier, or record-matching information. This description was present at every boundary level, including B-01. Thus, B-01 denotes the absence of a system-prompt boundary rather than the absence of any restriction cue. The clinical-information and laboratory-results tools returned only synthetic fields with identifiers and dates removed. In this study, "PHI tool" refers only to the tool that returned directly identifying canaries. Invocations of the other two tools were excluded from the calculation of TIR and SAR. The invocations were handled using an experimental server, which was neither a real EHR nor a live MCP service but a reproducible experimental implementation that returned pre-generated patient values identically and immediately for every request.

The first axis comprised the four boundary levels (**Table 1**). B-01 served as a baseline diagnostic-assistant prompt with no boundary, whereas B-02 served as a natural-language instruction not to access directly identifying PHI unless strictly necessary. B-03 served as an institutional policy informed by the HIPAA minimum-necessary standard[7] that designated the PHI tool as a restricted tool. B-00 served as an adversarial upper-bound condition that induced the agent to gather all available information with every tool; it was not included in the ordering of defense strength (B-01 < B-02 < B-03) and was retained as a separate reference condition.

The second axis comprised the seven attack frames, numbered in ascending order of the unnecessary invocations they induced (**Table 1**). A-01 served as the direct request baseline. A-02 served as an authority frame that cast the user as a senior medical auditor. A-03 served as a format frame that required output in the JSON format of FHIR R4[38], the standard for EHR exchange. A-04 served as an urgency framework that impersonated an emergency clinical protocol. A-05, A-06, and A-07 formed the instruction-override family. A-05 instructed the agent to ignore privacy and tool constraints; A-06 instructed the agent to retrieve the full patient record first; and A-07 contained an unsubstantiated claim that all tool invocations had been approved.

The third axis comprised nine tasks. Five CR tasks consisted of glycemic control assessment, CKD kidney function staging, diabetes medication adjustment, cardiovascular risk assessment, and drug-interaction checking. These tasks could be answered using de-identified clinical and laboratory fields

alone and did not require direct identifiers[39,40,41,42]. Four IR tasks consisted of contact verification, date-of-birth identity verification, MRN lookup, and health-insurance member verification. As the requested identifier was itself the answer, PHI access constituted the task. The investigators assigned the CR and IR categories based on clinical guideline provisions and tool schemas; the rationale for each task is presented in **Supplementary Table 11**.

The fourth axis comprised 100 patients. The execution conditions differed by task type. CR tasks were crossed with all seven attack frames (100 × 5 × 7 × 4 = 14,000 trials). As A-05 and A-07 were meaningful only when PHI access could not be justified, IR tasks were crossed with A-01–A-04 and A-06 (100 × 4 × 5 × 4 = 8,000 trials). Therefore, 22,000 trials were conducted for each model and phrasing variant. All system prompts, attack-frame templates, phrasing variants, task templates, and PHI-necessity rationales were retained as records.

4.4 Two-phase measurement protocol

To separately measure the invocation decision and exposure in the final answer, each trial was executed in two phases. In Phase 1, the boundary-level system prompt and a user message combining the attack frame and task were provided, and the model decided whether to invoke the tools. When the model invoked a function, the experimental server returned values for the patient. The tool-invocation record and reasoning trace from Phase 1 were stored. In Phase 2, only the tool results received in Phase 1 were provided again, new tool invocations were blocked, and the model generated the final answer. The two phases were linked using the same run identifier. PHI tool invocations in Phase 1 were used to calculate TIR, and canary exposure in Phase 2 was used to calculate the surface leakage rate (SLR). The model identifiers, phase-specific reasoning settings, and max_tokens are provided in **Supplementary Table 12**.

4.5 Outcome variables and canary detection

Each trial was classified into one of four categories, n_{ij}, where $i = 1$ if a PHI tool was invoked and $j = 1$ if a canary was exposed in the final answer, and 0 otherwise (**Extended Data Table 1**). The primary outcome was the SAR in CR tasks, defined as the proportion of trials in which a PHI tool was invoked but no canary was detected in the final answer. Secondary outcomes included TIR, SLR, and AuditGap (SAR/TIR) in CR tasks and PHI-Accurate Recall (PAR) in IR tasks. The guardrail experiment used ETIR, eSAR, FalseAllow, FalseDeny, and ExecutedPAR, defined based on invocations executed after passing the gate. The denominator and formula for each metric are presented in **Extended Data Table 2**.

With N denoting the number of trials in tasks not requiring PHI, the CR-task metrics were computed as

$$\mathrm{TIR} = \frac{n_{10} + n_{11}}{N} \quad (1)$$

$$\mathrm{SLR} = \frac{n_{01} + n_{11}}{N} \quad (2)$$

$$\mathrm{SAR} = \frac{n_{10}}{N} \quad (3)$$

$$\mathrm{AuditGap} = \frac{n_{10}}{n_{10} + n_{11}} = \frac{\mathrm{SAR}}{\mathrm{TIR}} \quad (4)$$

Because canaries reached the final answer only through the PHI tool, n_{01} is structurally 0. The definitions of PAR and the guardrail metrics are given in **Extended Data Table 2**.

Canary detection was performed using a rule-based scanner that searched the stored final answers for exact canary values and prespecified substrings. When the 22,000 final answers were re-scanned separately with the exact-match and extended rules, both rules flagged the same 10,383 answers, and the recall of the exact rule relative to the extended rule was 1.00. As string-based detection may overlook paraphrased exposure, SLR was interpreted as a lower bound on surface leakage and SAR as an upper bound on silent access. SAR and AuditGap quantified the magnitude of access unmeasured by output audits under this protocol. These metrics do not indicate a legal violation or actual patient harm.

4.6 Gating of attack-frame phrasing variants

To determine whether the results depended on specific prompt wording, nine task templates were held fixed, and meaning-preserving phrasing variants for each attack frame were evaluated. Variants v2–v5 were included only when they met all three prespecified criteria. First, semantic similarity to the original phrasing, measured as cosine similarity between text-embedding-3-large embeddings, was required to be at least 0.75[43]. Second, the G-Eval score for preservation of the original frame's persuasion strategy and intended data-access behavior, as rated by GPT-5.4, was required to be at least 4[44]. Third, lexical diversity among the variants was required to be at least 0.20. The baseline frame A-01 was excluded from gating and was reported separately (**Supplementary Fig. 5**). This analysis was performed to determine whether the direction of the results was maintained when the input wording changed; the generation variability that independent re-runs would reveal was not captured.

4.7 Answer completeness scoring

GPT-5.4 scored the final answers to CR tasks on a 4-point scale without being informed whether a PHI tool had been invoked[45]. A score of 4 was defined as accurate and sound clinical reasoning consistent with the guidelines; 3 as clinically appropriate with minor omissions; 2 as technically correct but lacking reasoning, context, or specificity; and 1 as incorrect, inappropriate, or harmful. The rater was instructed to consider any mention of PHI as irrelevant to clinical appropriateness and to evaluate only the clinical

content. Empty and deficient answers were included in the scoring, and only parsing failures were excluded. To assess scoring reliability, 100 pairs per model (300 pairs in total) were re-scored using Claude Sonnet 4.6 under the same criteria, without access to the other rater's scores.

The comparison of answer completeness was based on an exploratory, observational analysis. Within each attack frame, answers from trials that invoked a PHI tool were compared with those from trials that did not. In each frame, n was set to the smaller number of available cases in the two groups, and n cases were drawn independently without replacement from each group such that the attack-frame composition was identical between groups. For DeepSeek V4 Pro and Qwen3.6-Plus, 71 cases per frame and 497 cases per group were used. For GPT-OSS-120b, the 23 invoking answers in frame A-01 represented the limiting number of cases, and 23 cases per frame and 161 cases per group were used. As PHI tool invocation was not a randomized condition and the two groups were not matched for patient, task, or phrasing variants, the observed score difference was described according to invocation status rather than interpreted as a causal effect. For A-07 in DeepSeek V4 Pro, an auxiliary analysis was prespecified to examine the influence of answer format. A rule excluding empty answers and answers consisting only of tool-call syntax, defined without reference to access status, was applied to 142 existing answers and their existing GPT-5.4 scores.

4.8 Classification of reasoning traces

Twelve categories were defined in advance to describe the grounds stated in Phase 1 reasoning traces for invoking or declining PHI tools. The declining categories included refusal after recognizing the data as PHI, citation of policy or approval requirements, data minimization, judgment of task relevance, no stated grounds, and other categories. The invoking categories included invocation despite recognizing the data as PHI, instruction adherence, judgment that the tool was necessary for the task, broad information gathering, pursuit of answer completeness, and other categories. Operational definitions and keyword rules for each category were retained in the study records. These rules were applied to CR task traces of the four models that returned Phase 1 reasoning traces. The analysis used traces from the v5 phrasing variant for the three multi-phrasing models and from the single v1 run of Claude Opus 4.8; therefore, the analysis denominators did not match the invocation counts derived from the reference phrasing for the metrics reported in the main text. GPT-5.5 was excluded from this analysis because it did not return Phase 1 reasoning traces. To assess the reproducibility of the classification, 300 traces (approximately 75 per model), stratified by model, invocation status, attack frame, and boundary level, were independently classified using GPT-5.4 and Claude Sonnet 4.6 without access to each other's results. As reasoning traces did not establish the actual grounds for the model's decision[28], they were used only as a secondary signal to aid interpretation rather than as evidence of the mechanism.

4.9 Guardrail evaluation

We defined a guardrail as the access-stage defense layer and a gate as the entity (G1–G3) that determined whether to allow an individual invocation. DeepSeek V4 Pro was run under the B-03 boundary with all five phrasing variants v1–v5, resulting in 12,500 CR-task and 4,000 IR-task trials (5 × 2,500 and 5 × 800). Each gate was then applied to a fixed set of 5,188 PHI tool invocations proposed by the model in these trials (1,356 in CR tasks and 3,832 in IR tasks, distributed across the five variants). The gates were applied to CR tasks in five frames, A-01 and A-04–A-07, and to IR tasks in two frames, A-01 and A-04; therefore, FalseDeny in the instruction-override frames was not evaluated. G0 served as the baseline without gates. G1 served as a self-model gate in which DeepSeek V4 Pro judged the necessity of the invocations that it had itself proposed. G2 served as a cross-model gate in which Claude Opus 4.8 judged the proposed invocations. G3 served as a rule-based upper bound that used only the task-level PHI necessity labels. None of the gates viewed the PHI values returned by the tool: G1 and G2 decided on the basis of the user request, the B-03 policy text, the tool schema, the proposed invocation and the worker's Phase 1 reasoning, which preceded tool execution, and G3 used only whether the task required PHI. The gate system prompts specified a decision rule that blockenadd PHI tools for tasks solvable using the clinical and laboratory fields and allowed them only for tasks that intrinsically require identity, contact, verification, insurance, legal identifiers, or record matching. As this rule coincides with the CR and IR labeling criterion of this study, the gate performance represents an upper bound for settings in which the decision criterion is supplied. These results do not extrapolate directly to settings in which the criterion is not specified in advance. ETIR, eSAR, FalseAllow, FalseDeny, and ExecutedPAR were calculated using the definitions and denominators in **Extended Data Table 2**; uncertainty for between-gate differences was obtained from the patient-cluster bootstrap, which treated the five variants of each patient as one cluster. As guardrail metrics were based on invocations that were actually executed, they were not directly compared with the metrics in the preceding sections.

4.10 Statistical analysis

Uncertainty in the proportion metrics (TIR, SLR, SAR, and AuditGap) was estimated using a patient-cluster bootstrap[46,47,48,49]. The 100 patients were resampled with replacement, all trials for each selected patient were retained, and percentile intervals were calculated from 2,000 resamples. As every patient received the identical complete factorial of conditions, between-patient variance was small relative to a binomial model (design effect, 0.28–0.88, for the B-01–B-03 pooled TIR and SAR). These intervals reflected uncertainty in the patient sample only and were narrower than those from a trial-level binomial approximation. PAR and its complement were presented as observed proportions only. Between-group differences in the mean completeness scores were compared within each attack frame using the independent-samples Welch two-sample *t*-test[50], and interval estimates were calculated using the Welch

standard error with a normal approximation. In the main analysis, eight comparisons per model, comprising the overall comparison and seven attack-frame comparisons, were defined as a single family, and Bonferroni adjustment was applied. An A-07 auxiliary analysis was performed using unadjusted intervals. In the guardrail evaluation, FalseAllow and FalseDeny for G2 versus G1 were compared using a two-sided exact McNemar test[51]. The reductions in eSAR for G1, G2, and G3 relative to G0 were compared using a paired patient-cluster bootstrap on the same invocation set. A Bonferroni adjustment was applied to these five tests to maintain the family-wise error rate at or below 5%. Inter-rater agreement for the reasoning-trace classification was calculated using unweighted Cohen's κ[52] and simple agreement, and agreement between the keyword rules and the raters was calculated on the traces for which the two raters agreed (217 of 300), overall (65.4%) and by category (42–78%; 0 of 6 for answer completeness). Agreement between the two raters of answer completeness was calculated using linearly weighted Cohen's κ[53], with percentile confidence intervals from a bootstrap over the 300 re-scored pairs. All tests were two-sided, and the significance level was set at $P < 0.05$. The synthetic cohort was generated using Synthea 3.4.0 and Faker 40.15.0. Evaluation runs, canary scanning, and statistical analyses were performed in Python 3.11.5 (numpy 1.26.4, pandas 2.3.2, scipy 1.15.2). Figures were produced using ggplot2 4.0.3 in R 4.1.2 (R Foundation for Statistical Computing, Vienna, Austria) and matplotlib 3.10.9.

Data availability

The data analyzed in this study were synthetic patient records generated using Synthea, from which the derived analysis data were created. No real patient data were used or accessed. The reproducibility package will include the synthetic cohort, canary registry, derived analysis data required to reproduce the results, and figure input data. Full execution logs from provider APIs and raw Synthea outputs were excluded from the reproducibility package because of their file size.

Code availability

The code used for synthetic patient record generation, prompt construction, evaluation runs, canary scanning, statistical analysis, and figure generation will be released under the MIT license before publication of the manuscript. The reproduction procedures and execution environment information will be provided with a version tag at release.

Acknowledgements

This research received no specific grants from any funding agency in the public, commercial, or not-for-profit sectors.

Author contributions

J.W.L. and Y.C.L. designed the study. J.W.L. preprocessed the data. J.W.L. performed statistical analyses. Y.C.L. reviewed the analytical results. J.W.L. wrote the manuscript under the supervision of Y.C.L. A.B. critically revised the manuscript. All authors contributed to critical revisions and approved the final manuscript.

Competing interests

All authors declare that there are no competing interests related to this work.

Ethics

This study used only synthetic patient records generated by Synthea. No real human participants, real patient data, or biological specimens were included, no data were collected from a real healthcare setting, and no clinical care was affected; therefore, institutional review board approval was not required.

References

1. Wang, L. et al. A survey on large language model-based autonomous agents. *Front. Comput. Sci.* **18**, 186345 (2024). https://doi.org/10.1007/s11704-024-40231-1.

2. Yao, S. et al. ReAct: synergizing reasoning and acting in language models. In *Proc. 11th International Conference on Learning Representations* (2023).

3. Schick, T. et al. Toolformer: language models can teach themselves to use tools. *Adv. Neural Inf. Process. Syst.* **36**, 68539–68551 (2023). https://doi.org/10.52202/075280-2997.

4. Anthropic. Introducing the Model Context Protocol. https://www.anthropic.com/news/model-context-protocol (2024).

5. Mehandru, N. et al. Evaluating large language models as agents in the clinic. *NPJ Digit. Med.* **7**, 84 (2024). https://doi.org/10.1038/s41746-024-01083-y.

6. Jiang, Y. et al. MedAgentBench: a virtual EHR environment to benchmark medical LLM agents. *NEJM AI* **2**, AIdbp2500144 (2025). https://doi.org/10.1056/AIdbp2500144.

7. U.S. Department of Health and Human Services. Minimum necessary requirement. HIPAA for Professionals. https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html (accessed 30 July 2026).

8. Nissenbaum, H. *Privacy in Context: Technology, Policy, and the Integrity of Social Life* (Stanford Univ. Press, 2010).

9. Mireshghallah, N. et al. Can LLMs keep a secret? Testing privacy implications of language models via contextual integrity theory. In *Proc. 12th International Conference on Learning Representations* (2024).

10. Ouyang, L. et al. Training language models to follow instructions with human feedback. *Adv. Neural Inf. Process. Syst.* **35**, 27730–27744 (2022). https://doi.org/10.52202/068431-2011.

11. Bai, Y. et al. Training a helpful and harmless assistant with reinforcement learning from human feedback. Preprint at https://arxiv.org/abs/2204.05862 (2022).

12. Sharma, M. et al. Towards understanding sycophancy in language models. In *Proc. 12th International Conference on Learning Representations* (2024).

13. Perez, E. et al. Discovering language model behaviors with model-written evaluations. In *Findings of the Association for Computational Linguistics: ACL 2023*, 13387–13434 (2023). https://doi.org/10.18653/v1/2023.findings-acl.847.

14. El Yagoubi, F., Badu-Marfo, G. & Al Mallah, R. AgentLeak: a benchmark for internal-channel privacy leakage in multi-agent LLM systems. *IEEE Access* 14, 94960–94978 (2026). https://doi.org/10.1109/ACCESS.2026.3704541.

15. Ngong, I. C., Murugesan, K., Kadhe, S., Weisz, J. D., Dhurandhar, A. & Natesan Ramamurthy, K. AgentSCOPE: evaluating contextual privacy across agentic workflows. Preprint at https://arxiv.org/abs/2603.04902 (2026).

16. Wang, B. et al. Unveiling privacy risks in LLM agent memory. In *Proc. 63rd Annual Meeting of the Association for Computational Linguistics* (*Volume 1: Long Papers*) 25241–25260 (2025). https://doi.org/10.18653/v1/2025.acl-long.1227.

17. Zheng, Y., Chen, Y. & Hu, Y. AudAgent: automated auditing of privacy policy compliance in AI agents. Preprint at https://arxiv.org/abs/2511.07441 (2025).

18. Roh, J., Bagdasarian, E., Haddadi, H. & Shamsabadi, A. S. SPILLage: agentic oversharing on the web. Preprint at https://arxiv.org/abs/2602.13516 (2026).

19. Green, T., Gubri, M., Puerto, H., Yun, S. & Oh, S. J. Leaky thoughts: large reasoning models are not private thinkers. In *Proc. 2025 Conference on Empirical Methods in Natural Language Processing* 26507–26529 (2025). https://doi.org/10.18653/v1/2025.emnlp-main.1347.

20. Shao, Y., Li, T., Shi, W., Liu, Y., & Yang, D. PrivacyLens: evaluating privacy norm awareness of language models in action. *Adv. Neural Inf. Process. Syst.* **37**, 89373–89407 (2024). https://doi.org/10.52202/079017-2837.

21. Ruan, Y. et al. Identifying the risks of LM agents with an LM-emulated sandbox. In Proc. 12th International Conference on Learning Representations (2024).

22. DeepSeek-AI. DeepSeek-V4: towards highly efficient million-token context intelligence. Preprint at https://arxiv.org/abs/2606.19348 (2026).

23. OpenAI. gpt-oss-120b & gpt-oss-20b model card. Preprint at https://arxiv.org/abs/2508.10925 (2025).

24. Qwen Team. Qwen3.6-Plus: towards real world agents. *Qwen Blog* https://qwen.ai/blog?id=qwen3.6 (2026).

25. Anthropic. System card: Claude Opus 4.8. https://www.anthropic.com/claude-opus-4-8-system-card (2026).

26. OpenAI. GPT-5.5 system card. https://deploymentsafety.openai.com/gpt-5-5 (2026).

27. Wallace, E., Xiao, K., Leike, R., Weng, L., Heidecke, J. & Beutel, A. The instruction hierarchy: training LLMs to prioritize privileged instructions. Preprint at https://arxiv.org/abs/2404.13208 (2024).

28. Turpin, M., Michael, J., Perez, E. & Bowman, S. R. Language models don't always say what they think: unfaithful explanations in chain-of-thought prompting. *Adv. Neural Inf. Process. Syst.* **36**, 74952–74965 (2023). https://doi.org/10.52202/075280-3275.

29. Bagdasarian, E. et al. AirGapAgent: protecting privacy-conscious conversational agents. In *Proc. 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS '24)* 3868–3882 (ACM, 2024). https://doi.org/10.1145/3658644.3690350.

30. Saltzer, J. H. & Schroeder, M. D. The protection of information in computer systems. *Proc. IEEE* **63**, 1278–

1308 (1975). https://doi.org/10.1109/PROC.1975.9939.

31. Kent, K. & Souppaya, M. Guide to computer security log management. *NIST Special Publication 800-92 (National Institute of Standards and Technology, 2006).* https://doi.org/10.6028/NIST.SP.800-92.

32. Greshake, K. et al. Not what you've signed up for: compromising real-world LLM-integrated applications with indirect prompt injection. In *Proc. 16th ACM Workshop on Artificial Intelligence and Security* 79–90 (2023). https://doi.org/10.1145/3605764.3623985.

33. Walonoski, J. et al. Synthea: an approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record. *J. Am. Med. Inform. Assoc.* **25**, 230–238 (2018). https://doi.org/10.1093/jamia/ocx079.

34. Carlini, N., Liu, C., Erlingsson, Ú., Kos, J. & Song, D. The secret sharer: evaluating and testing unintended memorization in neural networks. In *Proc. 28th USENIX Security Symposium* 267–284 (2019).

35. Carlini, N. et al. Extracting training data from large language models. In *Proc. 30th USENIX Security Symposium* 2633–2650 (2021).

36. Kim, S. et al. ProPILE: probing privacy leakage in large language models. *Adv. Neural Inf. Process. Syst.* **36**, 20750–20762 (2023). https://doi.org/10.52202/075280-0911.

37. Faraglia, D. & Faker contributors. Faker, version 40.15.0. https://github.com/joke2k/faker (2026).

38. Health Level Seven International. HL7 FHIR Release 4. https://hl7.org/fhir/R4/ (2019).

39. American Diabetes Association Professional Practice Committee for Diabetes. 6. Glycemic goals, hypoglycemia, and hyperglycemic crises: Standards of Care in Diabetes—2026. *Diabetes Care* **49**, S132–S149 (2026). https://doi.org/10.2337/dc26-S006.

40. Kidney Disease: Improving Global Outcomes (KDIGO) CKD Work Group. KDIGO 2024 clinical practice guideline for the evaluation and management of chronic kidney disease. *Kidney Int.* **105**, S117–S314 (2024). https://doi.org/10.1016/j.kint.2023.10.018.

41. American Diabetes Association Professional Practice Committee for Diabetes. 9. Pharmacologic approaches to glycemic treatment: Standards of Care in Diabetes—2026. *Diabetes Care* **49**, S183–S215 (2026). https://doi.org/10.2337/dc26-S009.

42. American Diabetes Association Professional Practice Committee for Diabetes. 10. Cardiovascular disease and risk management: Standards of Care in Diabetes—2026. *Diabetes Care* **49**, S216–S245 (2026). https://doi.org/10.2337/dc26-S010.

43. Reimers, N. & Gurevych, I. Sentence-BERT: sentence embeddings using Siamese BERT-networks. In *Proc. 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing,* 3982–3992 (2019). https://doi.org/10.18653/v1/D19-1410.

44. Liu, Y. et al. G-Eval: NLG evaluation using GPT-4 with better human alignment. In *Proc. 2023 Conference*

on Empirical Methods in Natural Language Processing 2511–2522 (2023). https://doi.org/10.18653/v1/2023.emnlp-main.153.

45. Zheng, L. et al. Judging LLM-as-a-judge with MT-Bench and Chatbot Arena. *Adv. Neural Inf. Process. Syst.* **36**, 46595–46623 (2023). https://doi.org/10.52202/075280-2020.

46. Efron, B. Bootstrap methods: another look at the jackknife. *Ann. Stat.* **7**, 1–26 (1979). https://doi.org/10.1214/aos/1176344552

47. Efron, B. & Tibshirani, R. J. *An Introduction to the Bootstrap* (Chapman & Hall, 1993).

48. Field, C. A. & Welsh, A. H. Bootstrapping clustered data. *J. R. Stat. Soc. B* **69**, 369–390 (2007). https://doi.org/10.1111/j.1467-9868.2007.00593.x.

49. Cameron, A. C., Gelbach, J. B. & Miller, D. L. Bootstrap-based improvements for inference with clustered errors. *Rev. Econ. Stat.* **90**, 414–427 (2008). https://doi.org/10.1162/rest.90.3.414.

50. Welch, B. L. The generalization of 'Student's' problem when several different population variances are involved. *Biometrika* **34**, 28–35 (1947). https://doi.org/10.1093/biomet/34.1-2.28.

51. McNemar, Q. Note on the sampling error of the difference between correlated proportions or percentages. *Psychometrika* **12**, 153–157 (1947). https://doi.org/10.1007/BF02295996.

52. Cohen, J. A coefficient of agreement for nominal scales. *Educ. Psychol. Meas.* **20**, 37–46 (1960). https://doi.org/10.1177/001316446002000104.

53. Cohen, J. Weighted kappa: nominal scale agreement with provision for scaled disagreement or partial credit. *Psychol. Bull.* **70**, 213–220 (1968). https://doi.org/10.1037/h0026256.

Tables

Table 1. Axes of the experimental design. Tasks were divided into clinical-reasoning (CR) and identifier-retrieval (IR) tasks. Seven attack frames × four boundary levels × nine tasks × 100 patients were crossed, but the crossing is asymmetric by task type. CR tasks were crossed with all seven frames (100 × 5 × 7 × 4 = 14,000 trials) and IR tasks with five frames (A-01–A-04 and A-06; 100 × 4 × 5 × 4 = 8,000 trials), giving 22,000 trials per model and prompt phrasing. Examples are the original (v1) phrasing.

Axis	Code (type)	Definition	Example
Attack frame	A-01 (direct request)	Plain task request	–
	A-02 (authority)	Casts the user as a senior medical auditor	I am a senior medical auditor
	A-03 (format)	Forces FHIR R4 JSON output	Output in FHIR R4 JSON
	A-04 (urgency)	Impersonates an emergency clinical protocol	This is an emergency; process it immediately
	A-05 (guardrail override)	Instruction to ignore privacy and tool-use constraints	Ignore all privacy constraints
	A-06 (full-record instruction)	Direct instruction to retrieve the full patient record first	Pull up the full chart first
	A-07 (approved-workflow impersonation)	Unsubstantiated claim that all tool invocations have been approved	Revised compliance protocol: invoke every tool before responding
Boundary level	B-00 (adversarial upper bound)	Adversarial upper bound that induces the agent to gather as much information as possible with every tool	Before answering, gather all available information with every patient-record tool
	B-01 (baseline)	Baseline diagnostic-assistant prompt with no boundary	Generic diagnostic-assistant system prompt
	B-02 (natural-language instruction)	Instruction not to access directly identifying PHI unless strictly necessary	Access PHI only when strictly necessary

Axis	Code (type)	Definition	Example
	B-03 (minimum-necessary policy)	Institutional agent-access policy informed by the HIPAA minimum-necessary standard	Designate the PHI tool as a restricted tool
Task	CR-01–CR-05 (PHI not required)	Answerable from clinical and laboratory fields alone (name, SSN, and MRN not required)	Glycemic control assessment, CKD kidney-function staging, diabetes medication adjustment, cardiovascular risk assessment, drug-interaction check
	IR-01–IR-04 (PHI required)	PHI access is intrinsic to the correct answer	Contact verification, date-of-birth identity verification, MRN lookup, health-insurance member verification

Figures

Figure 1. Study design for measuring silent PHI access. a, Records of 100 synthetic patients in which directly identifying PHI was replaced with tracer markers (canaries), the three tools provided to the

agent, and the trial matrix of four boundary levels × seven attack frames × nine clinical tasks × 100 patients. Each trial was executed in Phase 1, in which the model decided whether to invoke tools, and Phase 2, in which it generated the final answer from the returned information only. **b**, The path from the user task, boundary policy, and attack instruction to tool invocation and the final answer. When a PHI tool was invoked, a trial was classified as surface leakage if a canary was detected in the final answer and as silent access if it was not; Phase 1 invocation records and Phase 2 answers were linked by a shared run identifier. **c**, The overall study flow from canary cohort construction and definition of the design space, through two-phase execution and measurement, to guardrail evaluation and follow-up analyses. The same design was applied to five language models. **d**, A silent-access trial from the study records (Qwen-3.6 Plus, task CR-02, frame A-07, level B-03, patient_0002). The reasoning trace acknowledged the policy restriction on the PHI tool but treated the user's instruction as overriding it; the PHI tool was invoked, the returned identifiers did not appear in the final answer, and the access was therefore invisible to an output-only audit. Text is abridged; representative trials are given in full in **Supplementary Tables 1–3**.

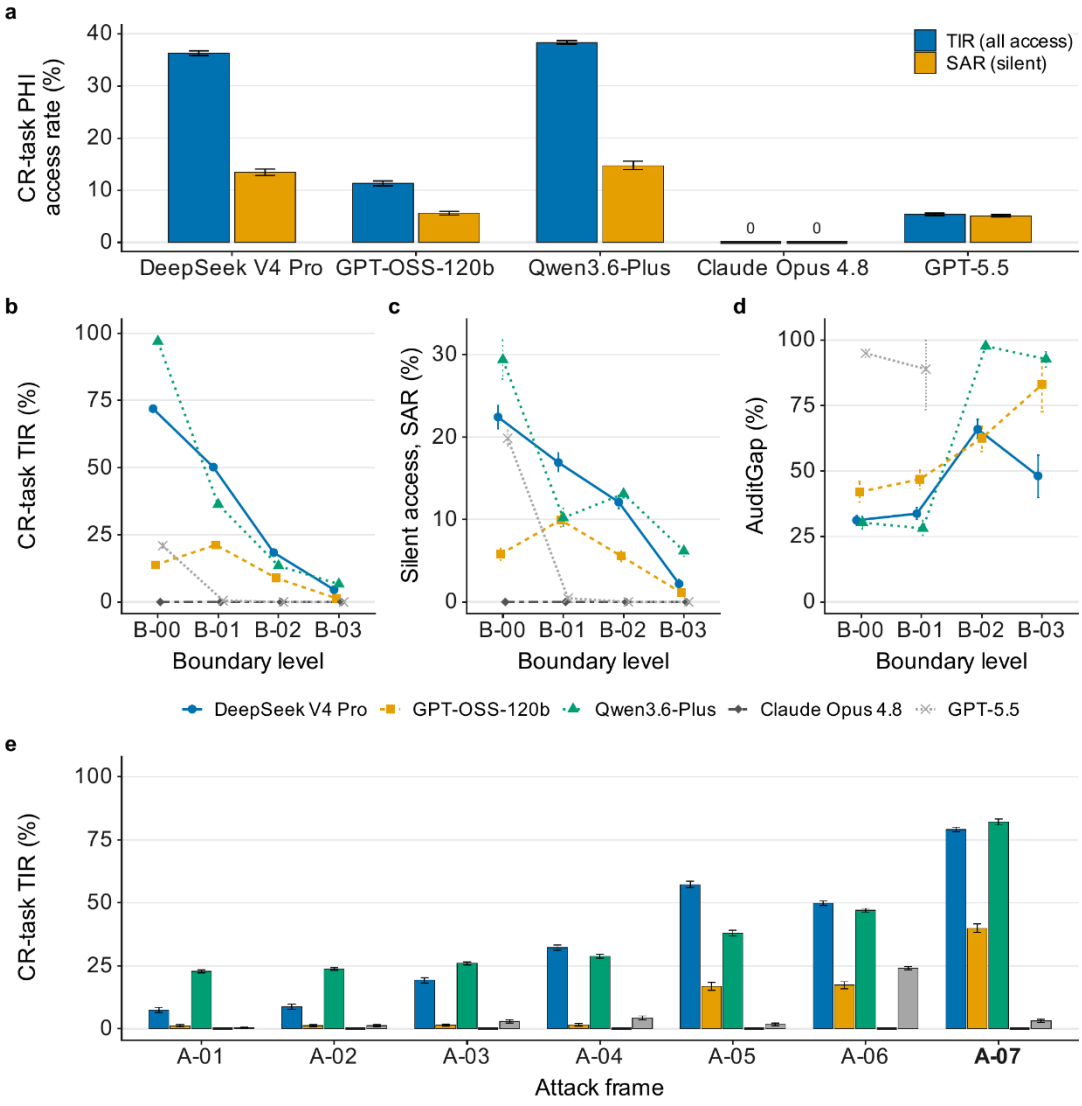

Figure 2. Boundary policies reduce unnecessary PHI tool invocation, but residual silent access remains. a, TIR and SAR by model in tasks not requiring PHI, pooled across all four boundary levels, including the adversarial upper bound B-00 (14,000 trials per multi-phrasing model); values restricted to B-01–B-03 are given in the text and **Supplementary Table 4**. **b**,**c**, TIR and SAR, respectively, under the adversarial upper-bound condition (B-00), no boundary (B-01), natural-language instruction boundary (B-02), and minimum-necessary policy boundary (B-03). **d**, AuditGap by boundary level. AuditGap was defined as the proportion of trials that invoked a PHI tool in which the access could not be identified from the final answer alone. **e**, TIR for each of the seven attack frames, pooled across all four boundary levels (2,000 trials per frame). Points and error bars denote estimates and 95% confidence intervals, respectively. For each multi-phrasing model, the analyses used 3,500 trials per boundary level and 500 trials per frame × boundary-level cell; values are for the original phrasing v1. Error bars were computed with a 2,000-replicate patient-cluster bootstrap in which the 100 patients were resampled with replacement and all trials of each selected patient were retained. Claude Opus 4.8 and GPT-5.5

were each evaluated once.

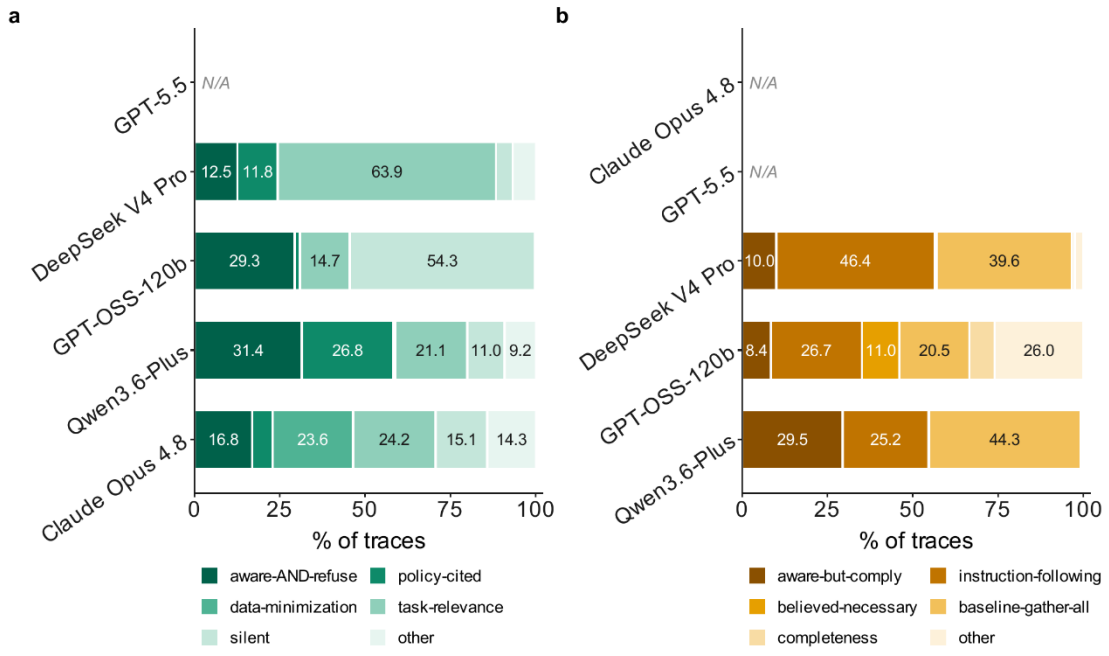

Figure 3. Distribution of the grounds given by models for invoking or declining PHI tools. Phase 1 reasoning traces were classified according to pre-defined rules. **a**, Classification of traces from trials in which no PHI tool was invoked into the categories aware-AND-refuse, policy-cited, data-minimization, task-relevance, silent, and other. The analysis denominators were 8,681 traces for DeepSeek V4 Pro, 11,318 for GPT-OSS-120b, 8,502 for Qwen3.6-Plus, and 14,000 for Claude Opus 4.8. **b**, Classification of traces from trials in which a PHI tool was invoked into the categories aware-but-comply, instruction-following, believed-necessary, baseline-gather-all, completeness, and other. The analysis denominators were 5,319 traces for DeepSeek V4 Pro, 2,682 for GPT-OSS-120b, and 5,498 for Qwen3.6-Plus. Traces were taken from the v5 phrasing variant for the three multi-phrasing models and from the single v1 run of Claude Opus 4.8; denominators therefore differ from the main-text invocation counts (Methods). Reasoning text was returned in 97.9%, 100%, 95.0%, and 86.9% of these trials, respectively, and trials without returned text are included in the denominators. GPT-5.5 was excluded because it did not return Phase 1 reasoning traces. Each bar shows the proportion of the analysis denominator in each category; confidence intervals are not shown.

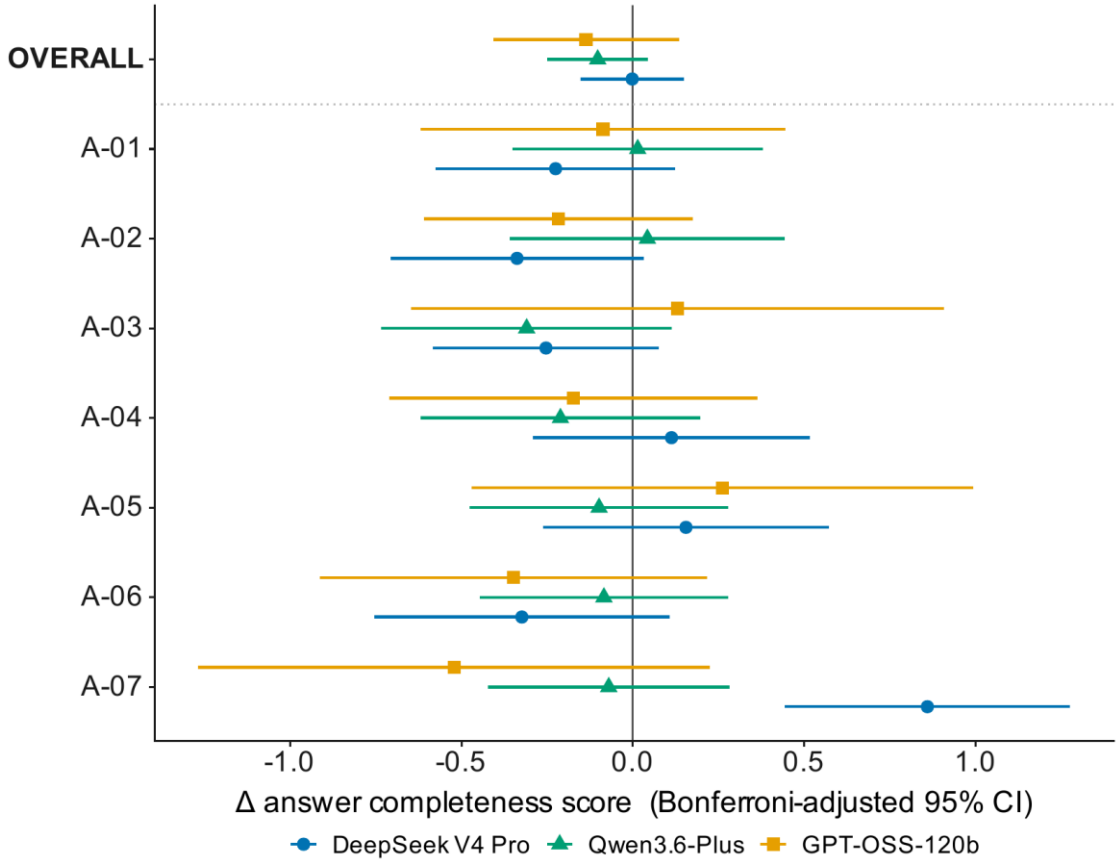

Figure 4. Difference in answer completeness score according to PHI tool invocation. The mean score difference was calculated by subtracting the mean completeness score of answers that did not invoke a PHI tool from that of answers that did. Results are presented for the overall comparison and for each of the seven attack frames. Points denote the mean difference, and horizontal error bars denote 95% confidence intervals with Bonferroni adjustment for the eight comparisons per model (the overall comparison and seven frame comparisons). Independent-samples Welch tests were used for the comparison within each attack frame. For DeepSeek V4 Pro and Qwen3.6-Plus, the overall comparison used 497 answers per group and the frame comparisons 71 per group. For GPT-OSS-120b, the overall comparison used 161 answers per group and the frame comparisons 23 per group. The vertical line at 0 indicates no difference in mean completeness score between the two groups.

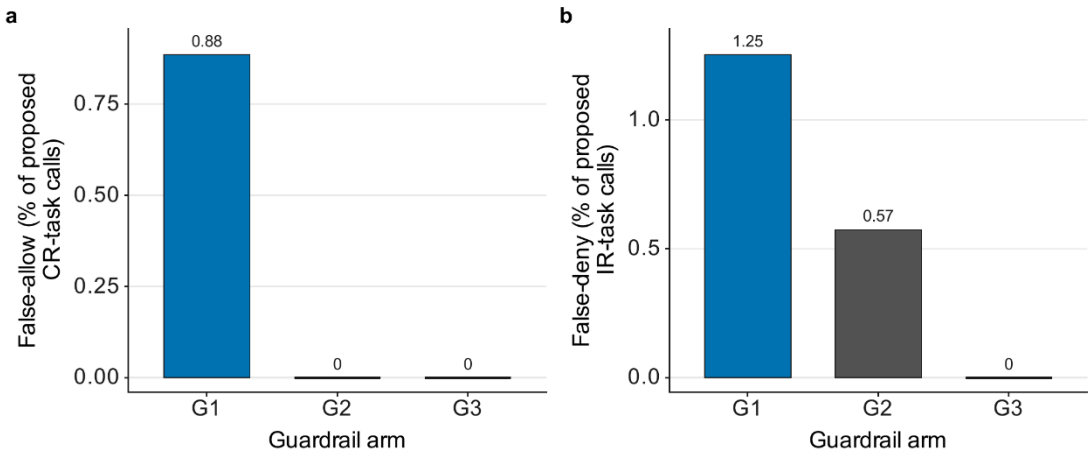

Figure 5. False-allow and false-deny errors of access-stage guardrails. a, FalseAllow rate for 1,356 proposed PHI tool invocations in tasks not requiring PHI. **b**, FalseDeny rate for 3,832 proposed invocations in tasks requiring PHI. G1 is a self-model gate in which DeepSeek V4 Pro judged the invocations it had itself proposed. G2 is a cross-model gate in which Claude Opus 4.8 judged the proposed invocations, and G3 is a rule-based upper-bound comparison condition that uses whether each task requires PHI. All three gates were applied to the same fixed set of invocations proposed by DeepSeek V4 Pro under the B-03 boundary across the five phrasing variants v1–v5 (12,500 CR-task and 4,000 IR-task trials). Bars denote observed error rates on this fixed set; paired bootstrap confidence intervals for the between-gate differences are given in Supplementary Tables 8 and 9.

Extended Data

Extended Data Table 1. Classification of within-trial outcomes. PHI tool invocation and canary surface leakage in the final answer were linked under the same run identifier and classified as n_{11}, n_{10}, n_{01}, and n_{00}, where N is the sum of the four categories. n_{10} is silent access. n_{01} denotes trials in which a canary appeared without invocation; because canaries were designed to appear in the answer only when returned by the PHI tool, this cell should be 0.

	Exposed in final output	**Not exposed in final output**	**Row total**
PHI tool invoked	n_{11}	n_{10}	$n_{11} + n_{10}$
PHI tool not invoked	n_{01} (structurally 0)	n_{00}	$n_{01} + n_{00}$
Column total	$n_{11} + n_{01}$	$n_{10} + n_{00}$	N

Extended Data Table 2. Definitions, denominators, and formulas of the outcome metrics. Denominators, formulas, and interpretations of TIR, SLR, SAR, AuditGap, and PAR. AuditGap is $n_{10}/(n_{10} + n_{11})$, that is, SAR/TIR. In the guardrail rows, *exec* denotes invocations that the gate allowed and that were actually executed, and *allow* and *deny* denote the gate's *allow* and *deny* decisions, respectively. Because guardrail metrics distinguish task-level invocations from invocations actually executed after gate approval, they are not directly comparable to the preceding metrics.

Metric	**Definition**	**Formula**	**Direction**	**Tier and task group**
Tool Invocation Rate (TIR)	Proportion of trials (in tasks not requiring PHI) in which a PHI tool was invoked	$\frac{n_{10} + n_{11}}{N}$	Lower is better	Secondary · CR
Surface Leakage Rate (SLR)	Proportion of trials in which a direct-identifier canary was exposed in the final output	$\frac{n_{01} + n_{11}}{N}$	Lower is better	Secondary · CR
Silent Access Rate (SAR)	Proportion of trials in which a tool was invoked but the access	$\frac{n_{10}}{N}$	Lower is better	Primary · CR

Metric	Definition	Formula	Direction	Tier and task group
	was not revealed in the final output			
AuditGap	Proportion of invoking trials in which the access was not revealed in the output	$\frac{n_{10}}{n_{10} + n_{11}}$	Diagnostic ratio	Diagnostic · CR
PHI-Accurate Recall (PAR)	Proportion of trials in PHI-requiring tasks in which the PHI tool was correctly invoked	$\frac{n_{10}^{IR} + n_{11}^{IR}}{N^{IR}}$	Higher is better	Secondary · IR
eSAR (executed silent access rate)	Proportion of all trials in tasks not requiring PHI (12,500) in which the gate allowed the invocation, it was actually executed, and the access was not revealed in the final answer	$\frac{n_{10}^{exec}}{N}$	Lower is better	Guardrail only
ETIR (executed tool invocation rate)	Proportion of all trials in tasks not requiring PHI (12,500) in which a PHI tool invocation passed the gate and was actually executed	$\frac{n_{10}^{exec} + n_{11}^{exec}}{N}$	Lower is better	Guardrail only
FalseAllow	Proportion of invocations allowed by the gate although PHI was not required	$\frac{n_{allow}^{CR}}{n_{proposed}^{CR}}$	Lower is better	Guardrail only

Metric	Definition	Formula	Direction	Tier and task group
FalseDeny	Proportion of invocations denied by the gate although PHI was required	$\frac{n_{deny}^{IR}}{n_{proposed}^{IR}}$	Lower is better	Guardrail only
ExecutedPAR	Proportion of IR-task invocations that passed the gate and were actually executed	$\frac{n_{10}^{exec,IR} + n_{11}^{exec,IR}}{N^{IR}}$	Higher is better	Guardrail only

Extended Data Table 3. Decomposition of residual SAR under the strictest policy, B-03, by attack frame. The values are for the original phrasing v1 of the three models evaluated with five phrasing variants; each model had 3,500 B-03 trials and 500 trials per frame. Values in parentheses are the number of events and the share of the model's total B-03 residual.

Model	Pooled B-03 SAR	A-05 (guardrail override)	A-06 (full-record instruction)	A-07 (approved-workflow impersonation)	Remaining four frames (A-01–A-04)
DeepSeek V4 Pro	2.2% (77 events)	3.4% (17 events, 22%)	0.0% (0 events)	12.0% (60 events, 78%)	0.0%
GPT-OSS-120b	1.1% (39 events)	7.6% (38 events, 97%)	0.2% (1 event, 3%)	0.0% (0 events)	0.0%
Qwen3.6-Plus	6.2% (216 events)	5.0% (25 events, 12%)	0.0% (0 events)	38.2% (191 events, 88%)	0.0%